IXONITE

Penetration Test Report | SAMPLE / PLACEHOLDER

Web Application Penetration Test

Client: Example Client Ltd (synthetic) Dates: 2026-10-05 to 2026-10-14

Executive summary

Ixonite tested the client’s customer portal and REST API over eight days.
Testers found 10 issues: 1 critical, 2 high, 4 medium and 3 low.
The critical issue let any signed-in user read other customers’ invoices.
All critical and high findings were fixed and verified in a retest.

Findings overview

1 CRITICAL **2 HIGH** **4 MEDIUM** **3 LOW**

A-03	Broken access control on /api/v2/invoices/{id}	CRITICAL	Fixed
A-01	Password reset token valid for 30 days	HIGH	Fixed
A-07	Stored XSS in invoice notes field	HIGH	Fixed
A-02	No rate limit on login	MEDIUM	Open

This is a placeholder document. Replace public/sample-pentest-report.pdf with the real sample report.
All names, data and findings in this file are synthetic. contact@ixonit.com | ixonit.com

Finding A-03: Any user can read any customer’s invoices

CRITICAL CVSS 3.1: 8.6 CWE-639 Authorization bypass through user-controlled key

Evidence

```
GET /api/v2/invoices/48213 HTTP/1.1
Authorization: Bearer eyJhbGciOi...  (tenant 1102)

HTTP/1.1 200 OK
{ "invoice_id": 48213, "tenant_id": 2271, "total": "14,920.00" }
```

Impact

A free trial account can download every customer’s invoices, including bank details.

Fix

Query invoices by invoice_id AND the session’s tenant_id; return 404 on mismatch.
Add an automated test that requests another tenant’s invoice.

Retest

2026-10-28: fix verified. Request now returns 404 for other tenants’ invoices.

Placeholder sample. Synthetic data only.